



COMMAND ROOM · SECURITY OVERVIEW

Command Room

Data security and architecture.

How Command Room handles your data. Plain English up front, full technical depth underneath. Every claim in the technical sections maps to a control you can verify in your own admin console or in Anthropic's Trust Center.

June 3, 2026

01 The short version

Command Room is instructions, not infrastructure. There is no Chalette server sitting between you and your data. Your working memory folder lives in storage you already own and govern: Google Drive, OneDrive, or a local folder. The AI model and the connectors are operated by **Anthropic**, whose security and compliance posture governs how your data is handled at runtime. Chalette never holds a standing copy of your data.

Practically: **if your organization is comfortable with your team using Claude against your own files and accounts, you are comfortable using Command Room.** Command Room does not add a new place your data goes. It adds a structured set of instructions that makes Claude useful at the speed of your business instead of the speed of copy-paste.

The five things that matter most

There is no Chalette server. Command Room is a set of plain-text instruction files. No backend to breach, no account we hold, nothing running on a Chalette machine.

Your files live in your storage. The working folder sits in your own Google Drive, OneDrive, or local folder, under the controls your company already uses. You can open, move, or delete it any time.

We do not get a copy. Chalette has no standing access to your inbox, your files, or your folder. We only see what you choose to show us in a working session.

Your data is not used to train AI. On a business plan that is contractual. On a personal plan it is a single setting we switch off together at setup.

Leaving takes about five minutes. Revoke the connections, uninstall the plugin, keep your folder. There is no Chalette data to delete, because we never had it.

Two honest caveats, up front

A real security review will find these anyway, so we lead with them.

- **Command Room is not local-only or air-gapped.** When the AI does work for you, your prompts and the connector data it reads travel to Anthropic for the model to process, and your Claude chat

history is retained by Anthropic under the data-handling terms of whichever Claude plan you are on.

- **Whether your data can be used to improve Anthropic's models depends on your Claude plan and one account setting.** On business (commercial) plans it never is. On individual (consumer) plans it is governed by a setting you confirm is off. We walk you through this at setup.

Architecture and controls

02 Command Room is a plugin. A plugin is instructions.

When most people hear software, they picture a backend somewhere: servers, databases, an account layer, a vendor holding a copy of your data. Command Room is not that.

Command Room is a **plugin**: a structured set of Markdown (plain-text) files that tell an AI assistant how to do specific things, such as how to triage your inbox, write a follow-up in your voice, log a decision, or assemble a board pack from your meeting notes. The AI reads those instructions the way a new hire reads an SOP binder.

That is the entire surface Chalette ships. No backend, no database, no login, no Chalette account to off-board. If you opened the plugin folder you would see text files. You could read them, change them, or delete them. There is a small amount of helper code (Python used to render on-screen widgets and write documents), but no Chalette-operated server and no Chalette data store.

Updates arrive the same way: as updated instructions you choose to install. The runtime checks for them; **Chalette cannot push anything to your machine**. Updates are manual, user-initiated, and inspectable before you accept them.

03 Cowork is the runtime. Your folder lives in your storage.

Plugins need somewhere to run. For Command Room that is Claude's Cowork mode, part of Anthropic's Claude desktop app, which loads the plugin, talks to the model, and reads and writes the files in your working folder.

Those reads and writes are scoped to the folder you point Cowork at. When a skill needs last week's meeting notes, it opens the file in your folder. When it drafts tomorrow's briefing, it saves the file in your folder. The folder is the system.

- **Google Drive** → the files live in Google Drive, under your existing Workspace governance.
- **OneDrive / SharePoint** → the same, under your Microsoft 365 governance.
- **Local folder** → it stays on that disk, on your own machine.

What is honest about local: the working folder is yours and is not sent to Chalette. But it is a working memory layer, and over time it accumulates a real corpus: names of people and projects you work with, meeting summaries, decisions, commitments, and, for voice-matching, verbatim text of some of your own sent emails. It is all in storage you own, readable and deletable by you. Treat the folder with the same DLP posture you would apply to any folder that holds business notes and correspondence.

04 Where your data actually goes

It helps to trace one request end-to-end.

"Triage my inbox."

Your email is read on-demand through Anthropic's connector → sent to Anthropic, where Claude processes it and produces the triage → the result is written back into a file in your working folder (for example, in your Google Drive, OneDrive, or local folder). No intermediate Chalette environment exists in that path.

1. **Processing happens at Anthropic, not on your laptop.** The model is Anthropic's. Your prompt and the data the connector returns transit to Anthropic over encrypted channels to be processed.
2. **Your chat history is stored by Anthropic** under your plan's retention terms. Connector results that appear in a chat are retained as part of that chat. This is the same behavior as any Claude conversation; Command Room does not change it.

05 Connectors: OAuth, least privilege, and your IT stays in control

Command Room reaches outside the working folder for live signal (email, calendar, Teams or Slack, meeting transcripts) through connectors operated by Anthropic. This is the part IT cares most about, so here is exactly how it works, using the Microsoft 365 connector, the most scrutinized, as the worked example.

DELEGATED OAUTH It is delegated, per-user OAuth. You authenticate on Microsoft's (or Google's) own login screen. Claude acts on your behalf and can only see and do what you can already see and do in that tool. It cannot reach another user's private mail or files, and it cannot bypass your existing SharePoint or folder permissions or DLP policies. Anthropic never receives your password.

READ-ONLY (M365) The Microsoft 365 connector has no write capability. It cannot send email, modify documents, schedule meetings, or post in Teams. Some other connectors (for example Gmail or Calendar) do offer send and create tools; those are governed by the per-tool approval gates below, and you can leave them off.

ADMIN CONSENT Admin consent is required, by design. A Microsoft Entra Global Administrator must grant a one-time consent before anyone in the tenant can connect, and on Team or Enterprise plans an Owner must also enable the connector in Claude's org settings. Your admin is in the loop on purpose; there is no way to side-step it.

You can scope it down or shut it off, at several layers:

- Revoke individual Graph permissions in Entra (for example, drop `Sites.Read.All` to block SharePoint, `Mail.Read` to block email). Changes take effect immediately.
- Restrict the connector to a specific pilot user or security group via Entra enterprise-app assignment before any wider rollout.
- Enforce your existing conditional access: MFA, managed or compliant devices, IP or VPN restrictions, and group-based access all apply unchanged.
- Disconnect per-user in seconds, or disable org-wide as an Owner.

Nothing runs silently. By default each connector tool requires your explicit approval before it executes; you can set any tool to auto-approve, ask-each-time, or block.

It is auditable in your own logs. Every Graph API call the connector makes is recorded in your Microsoft 365 audit log (Compliance Center): timestamp, user, operation, resource, under your own retention policy. Anthropic additionally logs authentication and tool-execution events.

Tokens are handled securely. The connector uses OAuth 2.0 On-Behalf-Of with PKCE; access and refresh tokens are encrypted and held by Anthropic's backend (never by Chalette), and tokens are cryptographically scoped to your tenant so there is no cross-tenant access.

One real-world note. Because the connector inherits your permissions, connecting an account that already has tenant-wide access (for example a CEO or admin) means Claude can read broadly as that person. That is expected behavior, not a leak. If you want a tighter blast radius, connect a least-privilege account or revoke the specific Graph scopes you do not need. Read-only access, on-demand retrieval, and full audit logging are the controls that bound it.

06 Anthropic is the trust layer

Because the model and the connector grants live at Anthropic, Anthropic's security and compliance posture governs the runtime data story. The trust evaluation your team would run on Command Room is, in substance, the trust evaluation of Anthropic, which many organizations have already completed.

Certifications and compliance

Verify current status and request reports at trust.anthropic.com.

CERTIFICATION	Scope
SOC 2 Type II	Annual independent third-party audit of security controls
ISO/IEC 27001:2022	Information security management system
ISO/IEC 42001:2023	AI management system
HIPAA	Business Associate Agreement (BAA) available to qualifying customers
GDPR	Data Processing Addendum (DPA) available
Encryption	In transit and at rest; reports available under NDA via the Trust Center

Model training: this is plan-dependent, so read carefully

- **Business / commercial plans** (Claude Team, Enterprise, and the Anthropic API / Claude for Work): your data is contractually never used to train models. This is the cleanest posture for an organization and the one we recommend for company data.
- **Individual / consumer plans** (Claude Free, Pro, Max): training is governed by a single account setting, "Help Improve Claude." If it is off, your chats are not used for training. If a user opts in, content can be retained de-identified for up to 5 years in training pipelines.

Two ways to guarantee your data is never used for training, pick either:

1. **Use a business (commercial) account** (Claude Team, Enterprise, or the API). Training is contractually prohibited; nothing to toggle. Recommended for company data.
2. **Turn off "Help Improve Claude"** on your individual account. Settings → Privacy (claude.ai/settings/data-privacy-controls). Once off, new chats are not used for training and previously stored chats stop being used in future training runs.

At setup we confirm you are on one of these two footings before connecting any company data. On either plan, the only carve-out is that conversations flagged by safety classifiers may still be used for trust-and-safety purposes.

Retention

Retention is also plan-dependent. On consumer plans, deleting a conversation removes it and it is purged from Anthropic's back-end within roughly 30 days; if model-improvement is off, the standard 30-day retention window applies rather than the 5-year training window. On commercial plans, retention is shorter and configurable, and Zero-Data-Retention agreements are available to qualifying enterprise customers. Trust-and-safety exceptions (flagged content) and legal holds apply on every plan.

The takeaway. For company data, run Command Room on a commercial Claude plan (Team, Enterprise, or API) and you get no-training-by-default, a DPA, shorter retention, SSO and role-based access and audit logs, and optional ZDR. On a consumer plan, the one thing to lock down is the model-improvement setting.

07 What Chalette sees, and does not

Chalette is a consulting firm, not a software host. There is no Chalette backend and no Chalette copy of your working folder.

What Chalette sees

- What you show us in working sessions. If you screen-share, we see your screen. If you send us a doc or transcript, we see that doc.
- What lands in spaces we explicitly share with you (a shared channel or folder).
- Anything you deliberately grant during setup, for example a one-time look at your folder while we configure a skill.

What Chalette does not see

- Your working folder in steady state. It lives in your storage; we have no ambient access.
- Your inbox, calendar, Teams or Slack. We hold no connector grants of our own.
- Anything the model reads or writes between our sessions. That is strictly between Cowork and your folder.

One honest exception. Command Room includes an optional “report a bug” action. If you ever use it, it drafts an email to Chalette containing limited diagnostics: plugin version, active connector names, anonymized workspace counts (no names), and your first name. No message content, no files. Nothing sends until you review the draft and click send. If your policy forbids even that, the feature can be disabled or pointed at your own helpdesk.

08 Off-boarding takes about five minutes

Because there is no Chalette account to close and no Chalette data store to purge:

1. **Revoke the connectors.** One action per service in your Google, Microsoft, or Slack admin. The plugin loses its inputs immediately.
2. **Uninstall the plugin** from Cowork. The instructions leave the runtime.
3. **Keep, archive, or delete the folder.** It is yours, in your storage. Keep it as a structured record, archive it cold, or delete it.
4. **Purge Claude history if desired.** To remove the conversation history held by Anthropic, delete your chats (purged within roughly 30 days) or close your Claude account, per Anthropic’s retention terms.

No data-deletion request to file with Chalette, because Chalette never held the data. No lock-in, because the folder is portable plain-text Markdown.

For your IT and security team

A one-page checklist so you can sign off with confidence.

Recommended posture for company data

- Use a **commercial Claude plan** (Team / Enterprise / API): no model training by default, DPA available, shorter and configurable retention, SSO and role-based access and audit logs, optional Zero Data Retention.
- If a user is on a **consumer plan**, confirm the model-improvement / training setting is OFF before connecting company accounts.

Connector governance (you control all of this)

- Connectors are **Anthropic-hosted, OAuth 2.0 delegated, per-user**. Claude inherits the connecting user's existing permissions and nothing more.
- **Microsoft 365 connector is read-only** (no send, modify, or post). Gate any write-capable connectors via per-tool approvals.
- **Admin consent is mandatory** (Entra Global Admin); Team and Enterprise add an Owner-level enable step.
- Scope down by revoking specific Graph permissions (Mail.Read, Sites.Read.All, Files.Read.All, Chat.Read, Calendars.Read); effective immediately.
- Pilot safely via Entra enterprise-app assignment to a named test group.
- Conditional access applies unchanged: MFA, device compliance, IP restrictions, group-based access.
- Audit every connector call in your M365 Compliance Center (Graph API logs) and Google admin logs.
- Revoke at user, permission, or tenant level at any time.

Data flow and residency

- **Working folder = your storage** (Drive / OneDrive / local), under your governance.
- **Runtime processing = Anthropic**; chat history retained per your plan. No Chalette server in the path.
- Connector data is **retrieved on-demand**, not bulk-cached by the connector.

Vendor (Chalette) risk

- No standing access to your data; no Chalette data store; cannot push updates to your machine.
- Engagement is a **services agreement** (like any consultant); we will sign a mutual NDA. A DPA for the data layer comes from **Anthropic**, the entity that actually processes data.

Documentation you can request

- Anthropic SOC 2 Type II, ISO 27001, ISO 42001 reports and subprocessor list at trust.anthropic.com (under NDA).
- Microsoft 365 connector security guide (Anthropic) for the exact permission and token model.
- A read-through of the plugin's Markdown instruction files on request. There is no hidden code path.

09 Common questions from IT reviews

Does this give the AI access to our whole tenant or everyone's data?

No. Access is delegated to the single connecting user and is capped at what that user can already access. It cannot reach other users' private mail or files. If that user is a broad-access admin, scope it down with a least-privilege account or by revoking specific Graph permissions.

Is our data used to train the model?

You can guarantee no, two ways: use a business account (Team, Enterprise, or API, where training is contractually prohibited), or, on an individual account, turn off the "Help Improve Claude" setting under Settings → Privacy. We confirm one of these is in place before connecting company data.

Can the AI send email or change files on its own?

The Microsoft 365 connector is read-only. Write-capable connectors exist (for example Gmail send) but every tool is approval-gated by default and can be left off.

What can we audit, and how do we revoke?

All connector activity appears in your own M365 or Google audit logs. Revoke per-user, per-permission, or tenant-wide in your admin console, instantly.

What if Anthropic has a breach?

Your exposure is that of any Anthropic customer using Claude with connectors; the pathway runs through Anthropic, not a separate Chalette layer. Anthropic's breach-notification and remediation processes, and DPA terms on commercial plans, apply.

Can we run this air-gapped?

No. The model runs at Anthropic and the runtime needs network access. If air-gap is a hard requirement, Command Room is not a fit today.

Does our legal or compliance team need to review something Chalette-specific?

Mostly the review is: is Anthropic / Claude on our approved-vendor list, and are our connector grants within policy? The Chalette piece is a standard services contract plus an NDA.

Questions we did not answer here? Bring them to the call. We are happy to walk you or your security team through any of this live.

Architectural claims verified against Anthropic's published documentation (Trust Center, Microsoft 365 connector security guide, consumer and commercial data-retention policies) and against Command Room's own architecture, current as of June 3, 2026. Plan-dependent terms (training, retention) change over time; re-verify against trust.anthropic.com before quoting specifics.